

Task 3 Notes – Web Application Security

Objective

The objective of this task was to understand and perform practical web application security testing using DVWA (Damn Vulnerable Web Application). The task focused on identifying common web vulnerabilities, understanding their impact, and learning the mitigation techniques used to secure modern web applications.

Tools Used

- Kali Linux
- DVWA (Damn Vulnerable Web Application)
- Burp Suite Community Edition
- Mozilla Firefox
- Apache Web Server
- PHP
- MySQL
- curl
- Oracle VirtualBox

1. SQL Injection

SQL Injection is a web application vulnerability that occurs when user input is directly included in SQL queries without proper validation.

Activities Performed

- Initialized the DVWA database.
- Performed a normal database query.
- Executed SQL Injection payloads.
- Extracted usernames and password hashes.
- Identified database version and database name.
- Enumerated database tables.
- Compared Low and High security levels in DVWA.

Sample Payload

1' OR '1'='1

Key Learning

- SQL Injection can expose confidential database information.
- Prepared statements and parameterized queries effectively prevent SQL Injection attacks.

2. Cross-Site Scripting (XSS)

Cross-Site Scripting allows attackers to inject malicious JavaScript into web pages viewed by other users.

Activities Performed

- Demonstrated Reflected XSS.
- Demonstrated Stored XSS.
- Executed JavaScript alert payloads.

Sample Payload

```
<script>alert('XSS')</script>
```

Key Learning

- XSS can lead to session hijacking, cookie theft, and malicious script execution.
- Input validation, output encoding, and Content Security Policy (CSP) help mitigate XSS attacks.

3. Cross-Site Request Forgery (CSRF)

CSRF forces authenticated users to perform unintended actions without their knowledge.

Activities Performed

- Accessed the DVWA CSRF module.
- Changed the user password.
- Verified successful login using the updated password.

Key Learning

- CSRF attacks exploit trusted user sessions.
- CSRF tokens and SameSite cookies significantly reduce this risk.

4. File Inclusion

File Inclusion vulnerabilities allow attackers to access unintended files stored on the server.

Activities Performed

- Performed Local File Inclusion (LFI).
- Displayed the contents of the /etc/passwd file.
- Attempted Remote File Inclusion (RFI).

Example Payload

../../../../etc/passwd

Key Learning

- File Inclusion can expose sensitive operating system files.
- File path validation and disabling remote file inclusion improve application security.

5. Burp Suite Advanced

Burp Suite is a web application security testing tool used to intercept, inspect, and modify HTTP requests.

Activities Performed

- Configured Burp Suite proxy.
- Intercepted login requests.
- Modified HTTP requests.
- Configured Burp Intruder.
- Explored payload configuration.
- Observed Community Edition limitations.

Key Learning

- Burp Suite helps identify insecure request handling and input validation issues.
- Proper server-side validation is essential to prevent request manipulation.

6. Security Headers Analysis

HTTP Security Headers provide additional protection against common web attacks.

Activities Performed

- Inspected HTTP response headers using curl.
- Analyzed available security headers.
- Attempted analysis using SecurityHeaders.com.

Command Used

```
curl -I http://192.168.56.102/dvwa
```

Key Learning

Important security headers include:

- Content-Security-Policy (CSP)
- X-Frame-Options
- X-Content-Type-Options
- Strict-Transport-Security (HSTS)

These headers help protect web applications against Clickjacking, Cross-Site Scripting, and MIME-type attacks.

Key Learning Outcomes

- Learned practical web application security testing.
- Performed SQL Injection attacks and database enumeration.
- Demonstrated Reflected and Stored Cross-Site Scripting.
- Performed Cross-Site Request Forgery testing.
- Explored Local and Remote File Inclusion vulnerabilities.
- Used Burp Suite for request interception and manipulation.
- Analyzed HTTP Security Headers.
- Understood secure coding practices and web application defense mechanisms.

Conclusion

This task provided valuable hands-on experience in identifying and analyzing common web application vulnerabilities using DVWA. Practical exposure to SQL Injection, XSS, CSRF, File Inclusion, Burp Suite, and Security Header analysis strengthened my understanding of secure web application development and ethical hacking methodologies.